



Qilin Threat Actor Profile

Threat Actor Profile

Classification	TLP:CLEAR
Published	2026-06-05
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Actor Profile

TLP:CLEAR | Lost Boys Cyber | Qilin Threat Actor Profile - Threat Actor Profile

Published: 2026-06-05 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary	
2. Intelligence Requirement	
3. Source Review and Confidence	
4. Key Findings	
5. Threat Context	
5.1 Actor Overview and Evolution	
5.2 Operating Model and Criminal Business Logic	
5.3 Victimology, Sector Exposure, and Geographic Patterning	
5.4 Notable Public Incident Context	
5.5 Initial Access Patterns	
5.6 Post-Compromise Tradecraft	
5.7 Payload, Platform, and Execution Characteristics	
5.8 Representative Sample Analysis and Artifact-Level Technical Notes	
5.9 Representative Intrusion Sequence and Decision Points	
5.10 ATT&CK Mapping	
6. Detection and Hunting	
6.1 Detection Strategy	
6.2 High-Value Telemetry Sources	
6.3 High-Confidence Detection Opportunities	
6.4 Example Hunt Hypotheses	
6.5 Sigma-Style Analytic Concepts	
6.6 Example KQL Hunting Ideas	
6.7 Hunting Priorities by Environment	
6.8 Scoping Questions During Incident Response	
7. Recommendations	
8. References	

1. Executive Summary

Qilin is a high-tempo ransomware-as-a-service operation that should be assessed as an intrusion ecosystem rather than a single malware family. Public reporting through 2025 and early 2026 indicates that the operation combines a central service layer responsible for payload generation, affiliate recruitment, leak-site operations, and ransom negotiations with affiliate crews that bring access, victim selection, lateral movement tradecraft, and victim-specific execution patterns. This operating model allows Qilin to maintain resilience even when individual campaigns are disrupted.

Qilin presents elevated enterprise risk because it combines double extortion, broad victimology, cross-platform encryption, and practical tradecraft that favors administrative-tool abuse over exotic malware. ATT&CK and vendor case reporting indicate support for Windows, Linux, and ESXi targeting; use of valid accounts and exposed remote services for initial access; aggressive credential theft and discovery; and strong interest in backup, virtualization, and high-availability infrastructure. The group’s operational effectiveness stems from chaining together familiar techniques quickly enough to compress defender response time.

The most consequential public incident remains the June 2024 Synnovis attack in the United Kingdom, which demonstrated that Qilin-linked operations can produce major downstream disruption to pathology workflows, appointment scheduling, and patient care. Reporting in 2025 further indicates that Qilin remained highly active, including activity against manufacturing, technology, healthcare, state and local government, and managed service provider environments. Sophos reporting also shows Qilin affiliates targeting ScreenConnect administrative access, reinforcing the threat the group poses to one-to-many service-provider environments.

The core defensive implication is that Qilin should be detected before encryption. The most reliable opportunities are around remote-service abuse, valid-account misuse, domain and share discovery, WDigest changes, credential dumping, PsExec or other lateral execution, WinRAR or equivalent staging, Cyberduck or other exfiltration tooling, backup or virtualization administration access, and log-clearing or recovery-inhibition behavior. Organizations that wait for ransom notes, mass file renames, or widespread encryption are already in the failure phase of the intrusion.

Dimension	Assessment
Threat model	Affiliate-enabled ransomware-as-a-service with double extortion
Activity window	Active since at least 2022; still prominent through 2025 and referenced in 2026 ATT&CK updates
Associated branding	Agenda in earlier reporting
Platforms at risk	Windows, Linux, VMware ESXi
Operational emphasis	Valid accounts, remote access abuse, discovery, credential theft, exfiltration, and recovery inhibition
High-risk environments	Healthcare, manufacturing, technology, SLTT, MSP, and backup-heavy enterprises
Best detection window	Access, discovery, credential access, and pre-impact staging
Overall enterprise risk	High

2. Intelligence Requirement

This report addresses the requirement to build a comprehensive threat actor profile on Qilin that can support executive understanding, defensive prioritization, detection engineering, threat hunting, and incident response planning.

Priority intelligence questions:

- What is Qilin, and how does it relate to the earlier Agenda branding?
- How does the Qilin business model function, and what is the division of labor between operators and affiliates?
- Which sectors, geographies, and victim types face the greatest exposure?
- Which initial access, credential access, discovery, lateral movement, exfiltration, and impact behaviors recur across public reporting?
- What technical artifacts and execution patterns are most useful for defenders?
- Which ATT&CK techniques and telemetry sources are most relevant to early detection?
- What immediate and near-term actions are most likely to reduce risk from a Qilin intrusion?

3. Source Review and Confidence

This assessment is based on public reporting available through 2026-06-05. The highest-value sources for procedural detail were MITRE ATT&CK software and group entries, Cisco Talos case reporting from October 2025, Sophos reporting on ScreenConnect-focused Qilin affiliate activity from April 2025, NHS England public updates on the Synnovis incident, HHS HC3 healthcare-sector reporting, and secondary context from CIS, Group-IB, SentinelOne, Check Point, GuidePoint, and ANY.RUN trend material. Lost Boys Cyber did not perform a fresh live detonation for this revision pass; the sample-analysis material below is therefore a representative synthesis of public technical reporting and ATT&CK procedure examples rather than a claim of direct malware execution in-house.

Source family	Primary value	Confidence	Caveats
MITRE ATT&CK S1242 and G1050	Stable mapping of actor, malware, and observed techniques	High	ATT&CK is concise and not intended as full case narrative
Cisco Talos October 2025 case reporting	Richest public procedural detail on Qilin intrusion workflows	High	Case-driven; not every affiliate will reproduce every observed step
Sophos April 2025 ScreenConnect reporting	Strong evidence of MSP-targeting and one-to-many downstream risk	High	Focused on one intrusion cluster and phishing-led access path
NHS England Synnovis updates	High-confidence public impact chronology	High	Limited procedural detail compared with IR vendor reporting
HHS HC3, Group-IB, SentinelOne, Check Point	Context on lineage, payload behavior, and sector risk	Moderate to high	Vendor scope and analytic emphasis vary

Source family	Primary value	Confidence	Caveats
CIS and ransomware trend reporting	Useful prevalence and victimology context	Moderate	Victim-posting statistics undercount incidents resolved privately

Confidence assessment:

- High confidence that Qilin has operated as a mature RaaS ecosystem since at least 2022 and has supported double extortion.
- High confidence that Qilin has targeted multiple sectors and countries, including healthcare-adjacent and public-sector environments.
- High confidence that Qilin affiliates rely heavily on valid accounts, remote-service abuse, legitimate administration tooling, and pre-impact data theft.
- Moderate confidence in exact victim totals or market-share comparisons because leak-site and incident-reporting datasets are incomplete proxies.
- Moderate confidence in attributing every public incident to a single Qilin affiliate cluster because public reporting often exposes the ransomware family but not the full evidentiary chain behind a specific crew.
- Moderate confidence in some technical details that derive from observed campaigns rather than universal encryptor behavior.

Analytic caveats:

- Public reporting frequently uses “Qilin” to refer interchangeably to the malware family, the operator group, and affiliate activity.
- Procedural drift is expected because affiliate crews can bring their own initial access routes, loaders, remote-management tooling, and exfiltration paths.
- Some procedure examples in ATT&CK are best treated as contextual enrichments, not as universal static indicators.

4. Key Findings

Finding	Why it matters
Qilin is an operating ecosystem, not just an encryptor	Defenders must plan for affiliate variation, operator infrastructure, and customized payload generation
Initial access and identity abuse matter more than ransom-note detection	The best time to stop Qilin is before enterprise-wide execution begins
Qilin repeatedly abuses legitimate tools	Psexec, PowerShell, WinRM, SSH, WinRAR, Cyberduck, and similar tooling produce valuable telemetry
Backup and virtualization infrastructure are strategic targets	Access to Veeam, vCenter, ESXi, or similar systems sharply increases recovery risk
Exfiltration should be assumed early	Qilin incidents should be scoped as both extortion and likely data-breach events until disproven
MSP and remote-management environments create amplified risk	One compromised administrative plane can enable downstream customer encryption

Finding	Why it matters
Static indicators alone are weak	Configurable payloads and affiliate variation require behavior-based detections
Healthcare and regulated sectors face disproportionate pressure	Qilin operations can convert IT compromise into immediate operational and regulatory consequences

5. Threat Context

5.1 Actor Overview and Evolution

Qilin emerged publicly in 2022 and is broadly associated with the earlier Agenda branding. Early reporting tied the family to Golang-based ransomware, while later ATT&CK and vendor reporting describe both Go and Rust-linked development and a more mature service architecture. The shift from Agenda to Qilin should be assessed as more than a cosmetic rename. Public reporting suggests a broader affiliate program, stronger operational branding, and richer configuration flexibility in later stages of the operation.

MITRE ATT&CK tracks Qilin as software S1242 and identifies Water Galura, also tracked as GOLD FEATHER, as the operator group behind the Qilin RaaS ecosystem. That distinction matters operationally. Water Galura appears responsible for payload generation, extortion infrastructure, leak-site operations, and affiliate support, while affiliates perform or materially shape victim-side intrusion work.

Attribute	Assessment
Public activity start	At least 2022
Associated software	Agenda, Qilin
ATT&CK software ID	S1242
ATT&CK group ID	G1050 Water Galura
Monetization model	Double extortion: encryption plus stolen-data pressure
Operator role	Payload generation, negotiations, leak-site management, affiliate enablement
Affiliate role	Access, discovery, privilege escalation, spread, exfiltration, and impact

5.2 Operating Model and Criminal Business Logic

Qilin fits the now-mature RaaS model in which core operators reduce the barriers to entry for affiliates while retaining centralized control over branding and monetization. This division of labor creates operational resilience, because disruption of one crew or one intrusion path does not eliminate the service layer.

Core operator function	Affiliate function
Generate customized encryptors and maintain brand infrastructure	Obtain access through phishing, stolen credentials, exposed services, or third-party compromise
Operate leak-site and extortion workflow	Conduct reconnaissance, privilege escalation, lateral movement, and local staging
Manage negotiations and payment pressure	Choose victim-specific tools and execution timing
Recruit or support affiliates through criminal channels	Monetize access opportunities and maximize leverage against the victim
Provide configuration options for Windows, Linux, and ESXi impact	Adapt execution to the victim's identity, backup, and virtualization environment

Operational implications of this model:

- Qilin can survive the loss of a single exploit chain because affiliates can rotate to other ingress paths.
- The same brand may present different forensic residue across incidents.
- Defensive teams should not anchor on one sample hash, one ransom note, or one initial access pattern.
- Attribution confidence should be framed around the ecosystem unless evidence clearly ties an intrusion to a specific affiliate cluster.

5.3 Victimology, Sector Exposure, and Geographic Patterning

ATT&CK and public reporting indicate that Qilin victims span the United States, Canada, the United Kingdom, France, Germany, and additional regions. Public reporting frequently highlights manufacturing, healthcare, technology, financial services, education, retail, construction, and government-linked environments. CIS reporting for Q2 2025 additionally identifies Qilin as a top ransomware threat to U.S. state, local, tribal, and territorial organizations.

Victimology dimension	Assessment
Commonly cited countries	United States, Canada, United Kingdom, France, Germany
Commonly cited sectors	Manufacturing, healthcare, technology, finance, education, retail, construction, SLTT
High-leverage target profiles	MSPs, healthcare providers, backup-centric enterprises, virtualized estates, remote-admin-heavy organizations
Primary coercive pressure	Operational disruption plus exposure of stolen data
Notable 2025 trend	High posting tempo and strong public visibility in ransomware reporting

Why these sectors are attractive:

- Manufacturing and logistics environments often have low tolerance for prolonged downtime and substantial OT-adjacent dependencies.
- Healthcare and healthcare-adjacent providers face immediate service-delivery and regulatory pressure.

- MSPs and remote-management providers can expose multiple downstream organizations from one administrative compromise.
- Public-sector and SLTT entities often combine constrained resources with high public-service impact.

5.4 Notable Public Incident Context

The June 2024 Synnovis incident remains the most strategically important public Qilin-linked case because it demonstrates how ransomware against a pathology provider can cascade into healthcare delivery disruption. NHS England states that Synnovis was attacked on 3 June 2024, with major effects on pathology services and more than 11,000 appointments and procedures. Public updates also note data publication and long-tail notification and recovery activity.

Incident	Defensive significance
Synnovis pathology attack, June 2024	Demonstrates severe downstream healthcare impact from a supplier compromise
Public publication of stolen data	Confirms double-extortion pressure beyond mere encryption
Prolonged service restoration and notification burden	Highlights legal, regulatory, and communications consequences
Broad visibility in public reporting	Makes Synnovis a useful reference case for executive risk framing

This incident matters because it shows that Qilin risk is not confined to data unavailability. For healthcare-adjacent entities, laboratory, scheduling, and patient-safety impacts can become immediate business and public-interest issues.

5.5 Initial Access Patterns

Public reporting portrays Qilin affiliates as opportunistic and adaptive rather than dependent on a single exploit path. Talos assessed with moderate confidence that some intrusions involved exposed administrative VPN infrastructure combined with compromised credentials and absent MFA. Sophos reported a 2025 campaign in which Qilin affiliates used spear-phishing against an MSP ScreenConnect administrator, then leveraged the stolen access to target downstream customers. Additional reporting associates Qilin with phishing, exposed RDP or Citrix services, remote-management abuse, and in some cases exploitation of backup or public-facing software.

Initial access pattern	Technical implication
Exposed VPN plus valid credentials	Strong path where MFA is absent or weak
RDP, Citrix, or other exposed remote services	Enables direct hands-on-keyboard access and rapid internal discovery
Spear-phishing and credential theft	Supports cloud-to-on-prem and MSP-centered access chains
ScreenConnect or remote-management compromise	Creates one-to-many downstream customer impact
Backup or public-facing software exploitation	Lets the actor target recovery-critical systems early
Weak privileged account hygiene	Increases speed of escalation once the foothold is obtained

Technical interpretation:

- Qilin's ingress diversity is a resilience feature of the affiliate model.
- Remote-service exposure and privileged identity drift are more actionable defensive priorities than searching for a single exploit signature.
- MSP and RMM administrators should be treated as high-impact identity assets.

5.6 Post-Compromise Tradecraft

Cisco Talos provides the richest public picture of Qilin's post-compromise workflow. Reported activity includes broad environment discovery, credential theft, use of password-protected tool archives, data packaging, SMTP-based transfer scripting, and staged exfiltration with legitimate or dual-use tools. ATT&CK further links Qilin to discovery, scheduled tasks, token manipulation, service stopping, event-log clearing, and recovery inhibition.

Representative post-compromise phases:

- Discovery: nltest.exe, net.exe, whoami /priv, tasklist, host and share enumeration, and PowerShell-based AD or vCenter reconnaissance.
- Credential access: WDigest UseLogonCredential modification, Mimikatz-adjacent tooling, SharpDecryptPwd, Browser credential collection, and token abuse.
- Data staging: WinRAR, local file review, packaging of collected material, and result aggregation.
- Exfiltration: SMTP-based transfer scripting in observed Talos cases, cloud-transfer utilities such as Cyberduck, and file-transfer utility abuse.
- Lateral movement: PsExec, SMB admin shares, WinRM, SSH, and reuse of stolen credentials.
- Defense evasion and impact preparation: event-log clearing, process and service termination, shadow-copy deletion, and recovery inhibition.

Phase	Representative behavior	Defensive value
Discovery	nltest, net user /domain, whoami /priv, tasklist, share enumeration	High-value early warning before encryption
Credential access	WDigest changes, credential dumpers, browser-password theft, token abuse	Strong indicator of intent to scale access
Staging	WinRAR archives, result consolidation, file review	Detectable exfiltration preparation window
Exfiltration	SMTP transfer scripts, Cyberduck, outbound file-transfer tooling	Critical for breach scoping
Lateral movement	PsExec, SMB shares, WinRM, SSH	Signals blast-radius expansion
Evasion and impact prep	wevtutil clearing, service stops, shadow-copy deletion	Often immediately precedes ransomware execution

5.7 Payload, Platform, and Execution Characteristics

Public reporting describes Qilin payloads as configurable and cross-platform. ATT&CK and supporting vendor analysis indicate support for Windows, Linux, and ESXi impact, configurable note behavior, process and service kill logic, and

execution controls that may require a password or operator-supplied argument. This makes purely static signatures weak and reinforces the need for telemetry around command lines, remote execution, and service-interaction patterns.

Capability area	Observed or reported behavior
Language lineage	Earlier Go-linked variants; later reporting includes Rust-linked development
Platform coverage	Windows, Linux, ESXi
Encryption references	Public reporting commonly cites AES-256 or ChaCha20 with RSA wrapping or equivalent asymmetric key protection
Execution guardrails	Password or victim-specific command-line arguments in some deployments
Impact preparation	Security and business-service termination, shadow-copy deletion, event-log clearing
Persistence examples	ATT&CK examples include RunOnce and scheduled-task abuse
Operator flexibility	Affiliate-customized naming, notes, deployment path, and spread logic

Representative ATT&CK procedure examples worth monitoring include a scheduled task named TVInstallRestore, a RunOnce reference to %Public%\enc.exe, and masqueraded naming such as TeamViewer_Host_Setup. These should be treated as enrichments and pivots, not as sole detections.

5.8 Representative Sample Analysis and Artifact-Level Technical Notes

The following analysis consolidates public observations into a defender-oriented sample profile. It is intended to answer the reviewer request for deeper technical analysis while clearly separating what is directly observed in public reporting from analytic interpretation.

Artifact or behavior	Publicly reported relevance	Analyst note
!light.bat	Talos reports a batch workflow that enabled WDigest UseLogonCredential	High-value precursor because it weakens credential protections before broader harvesting
netpass.exe and WebBrowserPassView.exe	Talos-linked credential collection tooling	Browser and stored-password theft expands cloud and internal pivot options
BypassCredGuard.exe and SharpDecryptPwd	Password decryption and credential access support	Indicates intent to overcome defensive hardening rather than relying only on LSASS dumping
Mimikatz functionality	ATT&CK maps embedded or adjacent credential and token abuse	Supports privilege escalation and multi-host spread

Artifact or behavior	Publicly reported relevance	Analyst note
pars.vbs	Talos describes VBScript that consolidated results and sent them via SMTP	Shows Qilin incidents can include lightweight scripted exfiltration rather than only large tooling stacks
result.txt	Consolidated stolen-data artifact mentioned in Talos reporting	Useful scoping artifact when recovered from disk or timeline analysis
WinRAR	Data packaging before exfiltration	Strong behavioral signal on servers where archive tooling is uncommon
Cyberduck	Cloud-transfer utility observed in Qilin cases	Useful for detections in environments where it is otherwise rare
encryptor_1.exe via PsExec	Talos reports host-to-host deployment using PsExec	Strong sign of interactive or service-based lateral execution
encryptor_2.exe against shares	Talos reports one-host execution against many network shares	Distinguishes centralized share targeting from broad binary propagation
C:\temp\w.exe	Example staging path and filename seen in public reporting	Weak standalone IOC, stronger when combined with other precursor behavior
TVInstallRestore task	ATT&CK procedure example of masqueraded scheduled task	Useful pivot for persistence hunting
%Public%\enc.exe	ATT&CK RunOnce example	Valuable for triage when seen with adjacent Qilin behaviors
SRManager.exe / Splashtop abuse	ATT&CK cites remote-management-assisted deployment of Linux ransomware on Windows in some reporting	Shows affiliate willingness to repurpose management infrastructure in unconventional ways

Sample-analysis judgments:

- Qilin's danger comes from orchestration more than novelty. The actor chains identity compromise, discovery, exfiltration, and impact in a compressed operational sequence.
- Multiple execution modes complicate scoping. A responder may see both classic host-to-host propagation and single-node network-share encryption in the same event set.
- Tooling overlap with normal administration is deliberate. Visibility therefore depends on context, frequency, source account, execution path, and unusual combinations of actions rather than simple tool presence.
- Lightweight artifacts such as batch files, VBScript, result aggregation text files, or renamed PsExec copies can be disproportionately valuable in reconstruction because they bridge access, staging, and impact phases.

5.9 Representative Intrusion Sequence and Decision Points

The reporting set supports a repeatable intrusion storyline that defenders can use as a practical hunt model. Not every Qilin event will include every step below, but the sequence reflects the most commonly recurring control failures and operational transitions seen across ATT&CK, Talos, Sophos, and public incident reporting.

Intrusion stage	Representative Qilin behavior	Why defenders should care
Access establishment	Phishing-led credential theft, exposed VPN or RDP access, ScreenConnect admin compromise, or other remote-service abuse	This is the cheapest point to contain the intrusion before privilege expansion
Internal orientation	Domain, host, share, backup, and virtualization discovery using built-in commands and administrative tooling	Distinguishes opportunistic initial access from deliberate enterprise-scale preparation
Credential expansion	WDigest weakening, password recovery tools, token abuse, browser credential theft, and credential dumping	This is where one foothold becomes many footholds
Data staging and theft	WinRAR, result aggregation files, SMTP scripts, Cyberduck, and ad hoc file transfer workflows	Confirms the event is likely a breach as well as a ransomware operation
Lateral execution planning	Psexec, WinRM, SSH, service creation, SMB admin shares, and task-based execution	Signals the actor is transitioning from access to blast-radius expansion
Recovery denial and impact	Log clearing, service termination, shadow-copy deletion, backup interference, and encryptor deployment across hosts or shares	Marks the point at which recovery costs and business disruption accelerate sharply

Operational decision points for defenders:

- If the first confirmed evidence is anomalous remote access, responders should immediately assume follow-on discovery and credential collection are already underway or imminent.
- If backup, vCenter, ESXi, or RMM systems appear in the same timeline as identity abuse, the event should be escalated as a high-probability enterprise ransomware incident rather than a single-host compromise.
- If archive creation, SMTP transfer logic, or cloud-transfer tools appear before encryption, breach-notification, legal, and privacy stakeholders should be activated in parallel with technical containment.
- If PsExec or equivalent execution appears from one orchestrating host, responders should test both host-to-host spread and one-node-many-share encryption paths rather than assuming only one deployment model.

5.10 ATT&CK Mapping

ATT&CK ID	Technique	Qilin relevance
T1133	External Remote Services	VPN, RDP, Citrix, and similar ingress are repeatedly relevant

ATT&CK ID	Technique	Qilin relevance
T1078	Valid Accounts	Stolen or weak credentials are central to many reported intrusions
T1566.001	Spearphishing Attachment	Common ingress path in public reporting
T1566.002	Spearphishing Link	Relevant to credential-capture workflows such as fake admin portals
T1003	OS Credential Dumping	Credential theft and password recovery are recurring themes
T1134	Access Token Manipulation	ATT&CK maps token theft and elevated execution behavior
T1059.001	PowerShell	Discovery and execution support behavior are frequently observed
T1018	Remote System Discovery	Strong pre-impact activity cluster
T1087	Account Discovery	Domain and local account enumeration appear repeatedly
T1135	Network Share Discovery	Critical precursor to spread and impact
T1021.002	SMB or Windows Admin Shares	Relevant to PsExec and service-based lateral movement
T1021.004	SSH	Important for Linux and ESXi operations
T1570	Lateral Tool Transfer	Applies to copy-and-execute propagation patterns
T1053.005	Scheduled Task	ATT&CK procedure examples support task-based execution or persistence
T1070.001	Clear Windows Event Logs	Frequently associated with pre-impact cleanup
T1490	Inhibit System Recovery	Central to ransomware impact preparation
T1486	Data Encrypted for Impact	Final ransomware impact technique

6. Detection and Hunting

6.1 Detection Strategy

The most effective Qilin detections are chained detections. Remote-service access, credential theft, discovery, backup-system access, exfiltration, and encryption should be correlated as one intrusion storyline rather than treated as isolated alert families.

Detection stage	High-value signal	Why it matters
Access	First-seen VPN, Citrix, RDP, or RMM access	Earliest likely foothold signal
Identity abuse	Unusual privileged-account or service-account activity	Often precedes broader discovery and spread
Discovery	Bursts of nltest, net, whoami, AD, vCenter, or share-enumeration commands	Strong warning before impact
Credential access	WDigest changes, browser-password tools, Mimikatz-like behavior	Indicates intent to scale access rapidly
Staging	Archive creation, WinRAR, result-file generation, unusual transfer tooling	Detectable exfiltration preparation window
Impact prep	Event-log clearing, shadow-copy deletion, service-stop bursts	Often immediately precedes encryption
Final impact	PsExec waves, share encryption, ransom notes, wallpaper changes	Late-stage confirmation and scoping

6.2 High-Value Telemetry Sources

Telemetry source	Priority use
VPN, Citrix, RDP gateway, and IdP logs	Identify first-seen or anomalous remote access
Windows Security, Sysmon, and PowerShell logging	Detect discovery, execution, and event-log abuse
EDR process, registry, file, and network telemetry	Correlate tool use, registry changes, and mass execution patterns
Email security and web proxy logs	Reconstruct phishing or credential-capture stages
Backup-platform and virtualization admin logs	Detect attempts to compromise recovery-critical systems
Linux, ESXi, and SSH logs	Scope cross-platform movement and impact
East-west network telemetry	Identify lateral spread and unusual service creation or SMB access

6.3 High-Confidence Detection Opportunities

Identity and access:

- Alert on successful remote-service logons from first-seen IPs, ASNs, countries, or device fingerprints, especially when followed by privileged internal access.
- Flag authentication to backup, Veeam, vCenter, ESXi, domain-admin, or RMM systems by accounts that do not normally administer them.
- Correlate bursts of failed remote authentications followed by a single success against the same exposure point.

Discovery and credential access:

- Hunt for nltest.exe, net.exe, whoami /priv, tasklist, PowerShell AD enumeration, and network share discovery launched from workstations, jump boxes, or servers that do not normally perform domain reconnaissance.
- Detect registry changes setting WDigest UseLogonCredential to 1.
- Alert on browser-password dumpers, SharpDecryptPwd, Mimikatz-like behavior, or process patterns associated with token abuse and credential decryption.

Staging and exfiltration:

- Flag WinRAR, Cyberduck, easyupload-related browser use, SMTP transfer scripts, or unusual archive creation on sensitive servers.
- Correlate outbound transfers shortly after local staging and discovery activity.
- Treat local files named result.txt or similarly aggregated credential or exfiltration manifests as high-priority triage artifacts when seen near other precursor behavior.

Impact preparation and execution:

- Detect wevtutil cl, PowerShell event-log clearing, vssadmin delete shadows, wbadmin deletion, bcdedit recovery changes, and broad service termination outside change windows.
- Alert on PsExec or renamed service-based execution from temp, public, or ad hoc staging paths.
- Monitor for abrupt SMB share write bursts, ESXi SSH enablement, or one-host multi-share encryption patterns.

6.4 Example Hunt Hypotheses

Hunt hypothesis	Expected evidence
If Qilin entered through remote services, the initial logon host will soon perform domain or share discovery	Remote logon plus nltest, net, whoami, PowerShell, or SMB enumeration
If Qilin is preparing enterprise-wide impact, privileged identity use will converge with PsExec, WinRM, or SSH activity	Shared source accounts or hosts administering many targets in a compressed time window
If Qilin targeted recovery systems, backup and virtualization infrastructure will show anomalous interactive access	Unexpected access to Veeam, vCenter, ESXi, or backup servers
If data theft occurred before encryption, archive creation and transfer tooling will appear before mass file modification	WinRAR, Cyberduck, SMTP-transfer scripting, outbound traffic spikes
If an MSP or RMM path was abused, common timing and parent-process patterns will repeat across multiple downstream organizations or hosts	Shared administrator identities, ScreenConnect-related artifacts, or repeated tenant overlap

6.5 Sigma-Style Analytic Concepts

Analytic title	Core logic	Escalate when
Suspicious bulk log clearing before ransomware impact	Detect wevtutil cl, ClearLog, or equivalent log-clearing commands outside maintenance workflows	Followed by shadow-copy deletion, service stops, or ransom-note creation within 60 minutes
Possible Qilin-like lateral execution via PsExec or equivalent	Alert on service-based execution from temp or public staging paths using PsExec, renamed copies, or PAExec	Same account or source host also performs discovery or credential-theft behavior
Suspicious credential-harvesting preparation on Windows	Detect WDigest UseLogonCredential modification plus credential-dumping or password-recovery utilities	Same host later accesses backup, admin, or multiple peer systems
Ransomware-context file transfer on servers	Detect Cyberduck, WinRAR, or unusual archive-and-transfer utility use on server-class assets	Paired with outbound exfiltration or network-share enumeration
Backup-plane compromise precursor	Detect unexpected admin logons to backup or virtualization consoles	Followed by service-stop, recovery-inhibition, or encryption activity

6.6 Example KQL Hunting Ideas

Example KQL concept 1: suspicious discovery and lateral-tool convergence

DeviceProcessEvents

where Timestamp > ago(7d)

where FileName in~ ("nltest.exe", "net.exe", "powershell.exe", "psexec.exe", "paexec.exe", "wmic.exe", "wevtutil.exe", "vssadmin.exe", "WinRAR.exe", "ssh.exe")

summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Hosts=dcount(DeviceName),

Devices=make_set(DeviceName, 20) by InitiatingProcessAccountName, FileName, ProcessCommandLine

order by Hosts desc

Example KQL concept 2: recovery inhibition or credential-harvesting preparation

DeviceProcessEvents

where Timestamp > ago(7d)

where ProcessCommandLine has_any ("wevtutil cl", "ClearLog", "vssadmin delete shadows", "wbadmin delete", "UseLogonCredential", "SharpDecryptPwd", "BypassCredGuard")

project Timestamp, DeviceName, AccountName=InitiatingProcessAccountName, FileName, ProcessCommandLine, InitiatingProcessFileName

order by Timestamp desc

Example KQL concept 3: anomalous access to backup or virtualization infrastructure

DeviceLogonEvents

where Timestamp > ago(14d)

where DeviceName has_any ("veeam","backup","vcenter","esxi")
 summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), SourceIPs=make_set(RemoteIP, 10),
 Devices=make_set(DeviceName, 20) by AccountName
 order by LastSeen desc

Example KQL concept 4: suspicious archive-and-transfer staging on servers

DeviceProcessEvents

where Timestamp > ago(7d)

where FileName in~ ("WinRAR.exe","Cyberduck.exe","winscp.exe")

summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Hosts=make_set(DeviceName, 20),

Cmds=make_set(ProcessCommandLine, 20) by InitiatingProcessAccountName, FileName

order by FirstSeen desc

6.7 Hunting Priorities by Environment

Environment	Priority hunts
Windows-heavy enterprise	PowerShell, Sysmon Event 1, service creation, share enumeration, WDigest changes, vssadmin, event-log clearing
Virtualized data center	vCenter and ESXi authentication, SSH enablement, datastore access, one-host multi-share encryption patterns
Healthcare and lab environments	Pathology, scheduling, laboratory, imaging, and data-export workflows; third-party service-provider access
MSP and multi-tenant environments	ScreenConnect, RMM, delegated admin, tenant overlap, downstream timing correlation
Government and SLTT environments	Internet-exposed remote services, weak privileged identities, shared admin accounts, and recovery-system access

6.8 Scoping Questions During Incident Response

Scoping question	Why it matters
What was the first confirmed access vector?	Determines whether the exposure path remains open
Which accounts touched VPN, RMM, backup, vCenter, ESXi, and domain control systems?	Defines privilege scope and blast radius
Is there evidence of data theft before encryption?	Changes legal, privacy, and communications posture
Which hosts show log clearing, recovery inhibition, or broad share discovery?	Identifies the operator's active pre-impact footprint
Was there PsExec, WinRM, SSH, WinRAR, Cyberduck, or SMTP-transfer activity?	Highlights the propagation and exfiltration channels

Scoping question	Why it matters
Were scheduled tasks, RunOnce entries, or masqueraded artifacts created?	Helps locate persistence and execution anchors
Did any MSP, ScreenConnect, or remote-management administrator accounts authenticate unusually?	Tests for one-to-many compromise risk

7. Recommendations

Priority	Recommendation	Rationale
Immediate	Enforce phishing-resistant MFA across VPN, RDP gateways, RMM, ScreenConnect, backup, vCenter, and privileged identity flows	Reduces the value of stolen credentials and phishing-led admin compromise
Immediate	Remove or tightly restrict direct exposure of RDP and similar administrative services	Shrinks one of the most common high-impact ingress paths
Immediate	Review and harden ScreenConnect, RMM, backup, and virtualization admin planes	These are high-leverage compromise points in Qilin intrusions
Immediate	Enable and retain Sysmon, Windows Security, PowerShell, identity, and centralized log coverage	Qilin behavior is detectable when the right telemetry exists
Near term	Correlate remote access, discovery, credential access, staging, and impact preparation into chained detections	Static or single-step alerts are too weak against affiliate variation
Near term	Control and monitor PsExec, SSH, WinRM, WinRAR, Cyberduck, and similar dual-use tools	Legitimate tooling abuse is central to Qilin operations
Near term	Segment backup, identity, management, and virtualization infrastructure from ordinary workstation and server tiers	Reduces blast radius and protects recovery capability
Near term	Exercise double-extortion response playbooks with legal, privacy, and communications stakeholders	Qilin incidents should be treated as likely breach events

Priority	Recommendation	Rationale
Ongoing	Hunt regularly for WDigest changes, anomalous backup-admin access, event-log clearing, and abnormal archive creation	These are high-value precursor behaviors
Ongoing	Validate offline or immutable backup restoration and ensure recovery dependencies are isolated from the main admin plane	Recovery integrity is decisive in Qilin cases
Ongoing	Review MSP, supplier, and delegated-admin trust relationships	One compromised service provider can amplify impact across customers

8. References

- MITRE ATT&CK. Qilin, Software S1242. <https://attack.mitre.org/software/S1242/>
- MITRE ATT&CK. Water Galura, Group G1050. <https://attack.mitre.org/groups/G1050/>
- Cisco Talos. Uncovering Qilin attack methods exposed through multiple cases. 26 October 2025. <https://blog.talosintelligence.com/uncovering-qilin-attack-methods-exposed-through-multiple-cases/>
- Sophos. Qilin affiliates spear-phish MSP ScreenConnect admin, targeting customers downstream. 1 April 2025. <https://news.sophos.com/en-us/2025/04/01/sophos-mdr-tracks-ongoing-campaign-by-qilin-affiliates-targeting-screenconnect/>
- NHS England. Synnovis cyber incident updates. <https://www.england.nhs.uk/synnovis-cyber-incident/>
- HHS Health Sector Cybersecurity Coordination Center. Qilin or Agenda Ransomware Threat Profile. 18 June 2024. <https://www.hhs.gov/sites/default/files/qilin-threat-profile-tpclear.pdf>
- Group-IB. The Qilin Ransomware: Analysis and Protection Strategies. 15 May 2023. <https://www.group-ib.com/blog/qilin-ransomware/>
- Group-IB. Qilin Revisited: Diving into the techniques and procedures of the recent Qilin ransomware attacks. 17 July 2024. <https://www.group-ib.com/blog/qilin-revisited/>
- Center for Internet Security. Qilin: Top Ransomware Threat to SLTTs in Q2 2025. <https://www.cisecurity.org/insights/blog/qilin-top-ransomware-threat-to-slts-in-q2-2025>
- SentinelOne. Agenda, Qilin Ransomware: In-Depth Analysis, Detection, and Mitigation. <https://www.sentinelone.com/anthology/agenda-qilin/>
- Check Point. Qilin Ransomware / Agenda deep-dive overview. <https://www.checkpoint.com/cyber-hub/threat-prevention/ransomware/qilin-ransomware/>
- GuidePoint Security. GRIT 2026 Ransomware and Cyber Threat Report. <https://www.guidepointsecurity.com/wp-content/uploads/2026/01/GRIT-2026-Ransomware-and-Cyber-Threat-Report.pdf>
- ANY.RUN. Qilin Ransomware analysis and overview. <https://any.run/malware-trends/qilin/>
- Trend Micro. Agenda Ransomware deploys Linux variant on Windows systems through remote management tools and BYOVD techniques. 23 October 2025.

Review artifact path: /home/lost0x01/internal-secops-portal/data/RAIccoon_Reports/In
Review/Qilin_Threat_Actor_Profile_Threat_Actor_Profile_Review.pdf